

ICS Security Assessment Checklist

A phase-by-phase guide to assessing and securing your SCADA and industrial control systems

- ✓ Pre-assessment preparation checklist (20 items)
- ✓ Assessment methodology: passive, active, and compliance
- ✓ NIST 800-82 / IEC 62443 framework alignment
- ✓ Post-assessment remediation prioritization

Phase 1: Pre-Assessment Preparation (Weeks 1-4)

Governance & Stakeholders

- ☐ Appoint executive sponsor (VP Operations, CISO, or Plant Manager)
- ☐ Form assessment team: OT engineering, IT security, operations, safety, compliance
- ☐ Hire or engage ICS/SCADA security consultant (see Vetting Guide)
- ☐ Define assessment scope: which facilities, systems, networks, and protocols
- ☐ Establish rules of engagement: what can be scanned, what is off-limits, maintenance windows
- ☐ Obtain legal review of assessment scope and consultant contract

Documentation Gathering

- ☐ Collect current network architecture diagrams (IT and OT networks)
- ☐ Gather OT asset inventory (PLCs, RTUs, HMIs, historians, engineering workstations)
- ☐ Document all network connections between IT and OT (including remote access, vendor connections)
- ☐ Collect firmware versions and patch levels for all OT devices
- ☐ Gather safety-instrumented system (SIS) architecture documentation
- ☐ Document current security policies, procedures, and incident response plans
- ☐ Compile previous assessment reports, audit findings, and vulnerability data
- ☐ Map the Purdue Model for your facility (Levels 0-5)

Operational Preparation

- ☐ Schedule maintenance windows for any active testing
- ☐ Identify rollback procedures for every system that will be actively tested

- ☐ Ensure backup systems and manual overrides are verified and operational
- ☐ Brief operations staff on assessment activities and timeline
- ☐ Establish communication protocol between assessment team and control room

Safety First

Before any active assessment work begins, the assessment team must review the SIS architecture and verify that safety systems are isolated from the assessment scope OR that appropriate safety measures are in place. Active scanning of safety-instrumented systems is never acceptable without a formal HAZOP review.

The Purdue Model: Where to Assess

Understanding Your ICS Architecture — The Purdue Model

Visual reference

Design a layered diagram showing the Purdue Model levels:

- **Level 5: Enterprise Network** — ERP, email, internet access, corporate IT
- **Level 4: Site Business Planning** — Production scheduling, asset management, historians
- **Level 3.5: DMZ** — Data diodes, jump hosts, historian mirrors (IT/OT boundary)
- **Level 3: Site Operations** — SCADA servers, engineering workstations, HMI servers
- **Level 2: Area Supervisory Control** — Operator HMIs, supervisory control applications
- **Level 1: Basic Control** — PLCs, RTUs, DCS controllers, safety controllers
- **Level 0: Physical Process** — Sensors, actuators, valves, motors, physical equipment

Color coding by assessment risk

- Levels 5-4: Standard IT security assessment (green — low operational risk)
- Level 3.5 DMZ: Critical boundary — high assessment value (amber)
- Levels 3-2: OT assessment zone — operational risk requires care (amber)
- Levels 1-0: Safety-critical — active testing requires maintenance window and safety review (red)

The IT/OT Boundary (Level 3.5 DMZ) is where most attacks enter.

A well-designed assessment spends 40-50% of its time at this boundary — examining what traffic crosses between IT and OT, what remote access paths exist, and whether the segmentation actually works.

Phase 2: Passive Assessment (Weeks 2-6)

Passive Assessment Activities

- ☐ Deploy passive network sensors at key monitoring points (IT/OT boundary, OT backbone)
- ☐ Capture and analyze OT network traffic (Modbus, DNP3, OPC UA, EtherNet/IP)
- ☐ Identify all communicating devices and build asset inventory from network data
- ☐ Map communication flows between IT and OT zones
- ☐ Identify unauthorized connections, rogue devices, and unexpected traffic
- ☐ Analyze industrial protocol traffic for anomalies and insecure configurations
- ☐ Review remote access configurations (VPN, TeamViewer, RDP, vendor portals)
- ☐ Assess network segmentation effectiveness (verify DMZ isolation)
- ☐ Review authentication mechanisms on OT systems (default passwords, shared accounts)
- ☐ Examine logging and monitoring coverage (what events are captured vs. missed)

Passive Assessment Deliverables

Deliverable	Description
OT Asset Inventory	Complete list of discovered devices with make/model/firmware/IP/network position
Network Architecture Diagram	As-built OT network topology (often differs from documented architecture)
Communication Flow Matrix	Which devices talk to which, on which ports and protocols
Vulnerability Findings (passive)	Identified risks without active probing (default creds, insecure protocols, missing segmentation)
Risk Prioritization	Findings ranked by exploitation likelihood and operational impact

Passive assessment often reveals 70-80% of critical findings

without touching a single device. Default passwords on HMIs, unencrypted industrial protocols crossing the IT/OT boundary, and undocumented vendor VPN connections are all discoverable passively. Start here before committing to active testing.

Phase 3: Active Assessment (Weeks 4-8, During Maintenance Windows)

Pre-Active Testing Safety Checklist

- ☐ Maintenance window scheduled and confirmed with operations
- ☐ Rollback procedures documented and verified for every target system
- ☐ Safety-instrumented systems confirmed isolated from test scope (or HAZOP review completed)
- ☐ Control room operators briefed and monitoring for anomalies
- ☐ Emergency stop procedures reviewed and accessible
- ☐ Communication channel established between assessment team and control room (radio, phone)

Active Assessment Activities

- ☐ Conduct targeted vulnerability scanning of OT devices (using ICS-safe tools and settings)
- ☐ Test authentication on SCADA servers, HMIs, and engineering workstations
- ☐ Attempt lateral movement from IT network to OT network
- ☐ Test remote access controls (VPN bypass, vendor portal security)
- ☐ Assess PLC/RTU firmware for known vulnerabilities (CVE matching)
- ☐ Test network segmentation by attempting cross-zone communication
- ☐ Evaluate backup and recovery capabilities (can OT systems be restored?)
- ☐ Conduct targeted exploitation of high-risk findings (with explicit approval per target)

Active Testing Ground Rules

(1) Never scan safety-instrumented systems without HAZOP review. (2) Never test in production during operating hours unless specifically authorized. (3) Always have a rollback plan BEFORE

testing. (4) Stop immediately if any process anomaly is detected. (5) Document every action taken on every device.

Phase 4: Compliance Mapping (Weeks 6-10)

NIST 800-82 Rev. 3 Assessment Checklist

- ☐ **Govern:** OT security governance policies documented and approved
- ☐ **Identify:** Complete OT asset inventory with risk categorization
- ☐ **Identify:** OT-specific threat model developed (ICS threat actors and TTPs)
- ☐ **Protect:** Network segmentation implemented (IT/OT boundary, zone model)
- ☐ **Protect:** Access control enforced (authentication, authorization, least privilege)
- ☐ **Protect:** Encryption in transit for all IT/OT boundary traffic
- ☐ **Detect:** Continuous OT network monitoring deployed and operational
- ☐ **Detect:** Log aggregation and correlation for OT events
- ☐ **Respond:** ICS-specific incident response plan documented and tested
- ☐ **Recover:** OT system backup and recovery procedures tested

IEC 62443 Zone Assessment

- ☐ Define zones and conduits for all ICS/SCADA systems
- ☐ Assess current Security Level Achieved (SL-A) for each zone against FR1-FR7
- ☐ Establish target Security Level (SL-T) for each zone based on risk assessment
- ☐ Identify gaps between SL-A and SL-T
- ☐ Develop remediation plan with timeline and resource requirements

IEC 62443 Foundational Requirements

FR	Requirement	What It Covers
FR1	Identification and Authentication Control	User/device authentication, account management
FR2	Use Control	Authorization, permissions, least privilege
FR3	System Integrity	Communication integrity, malware protection
FR4	Data Confidentiality	Encryption, information protection
FR5	Restricted Data Flow	Network segmentation, zone boundaries
FR6	Timely Response to Events	Monitoring, logging, audit trails
FR7	Resource Availability	DoS protection, backup, recovery

Phase 5: Remediation Prioritization (Weeks 8-12)

Prioritizing Fixes — The ICS Risk Matrix

Remediation Priority Matrix

Priority	Criteria	Timeline	Examples
P0 — Critical	Exploitable remotely, impacts safety or physical process control	0-30 days	Internet-exposed HMI, default PLC passwords, no IT/OT segmentation
P1 — High	Exploitable from IT network, impacts OT availability or integrity	30-90 days	Weak DMZ segmentation, unpatched Windows on SCADA servers, shared admin accounts
P2 — Medium	Requires internal OT access, impacts monitoring or compliance	90-180 days	Missing logging, unencrypted OT protocols, no MFA on remote access
P3 — Low	Requires physical access or complex exploit chain	6-12 months	USB port access, legacy protocol on isolated segment, documentation gaps

Common Remediation Actions and Costs

Remediation	Typical Cost	Impact
Change default passwords on PLCs/HMIs	\$0 (labor only)	Eliminates #1 ICS attack vector
Implement IT/OT network segmentation	\$25,000–\$100,000	Prevents lateral movement from IT to OT
Deploy OT network monitoring	\$50,000–\$250,000	Continuous visibility into OT traffic and threats
Secure remote access (jump host + MFA)	\$10,000–\$50,000	Eliminates vendor VPN backdoor risk
Develop ICS incident response plan	\$10,000–\$30,000	Prepared response vs. improvised chaos

Remediation	Typical Cost	Impact
Patch management program (compensating controls for unpatchable systems)	\$15,000–\$50,000	Risk reduction for legacy/EOL devices
Cybersecurity awareness training for OT staff	\$5,000–\$15,000	Reduces social engineering and human error risk
Implement ICS-safe antivirus/application whitelisting	\$20,000–\$75,000	Endpoint protection that doesn't crash PLCs

Start with the free wins.

Changing default passwords, disabling unnecessary services, and removing unauthorized remote access connections cost nothing but labor — and they eliminate the most common ICS attack vectors. Do these before spending on monitoring solutions.

Ongoing Security Program

Assessment Is Not a One-Time Event — Build an Ongoing Program

Annual OT Security Calendar

Frequency	Activity	Who
Continuous	OT network monitoring and alerting	Internal SOC or MSSP
Monthly	Review OT security alerts and incidents	OT security team
Monthly	Patch review for OT systems (apply during maintenance windows)	OT engineering + IT security
Quarterly	Review and update OT asset inventory	OT engineering
Quarterly	Tabletop exercise (rotate scenarios: ransomware, insider, nation-state)	Cross-functional team
Every 6 months	Vulnerability scan refresh (passive)	Consultant or internal team
Annually	Full ICS security assessment	External consultant
Annually	ICS incident response plan test (full drill, not tabletop)	Operations + security + safety
Annually	Compliance audit / evidence review (NERC CIP, IEC 62443)	Compliance + external auditor
Annually	OT cybersecurity awareness training refresh	All OT staff
Every 2-3 years	Full ICS penetration test	External consultant
As needed	Post-incident assessment	External consultant

Cost comparison: Reactive vs. Proactive

Factor	Reactive (No Program)	Proactive (Ongoing Program)
Annual cost	\$0 until incident	\$100,000–\$400,000/yr
Incident response cost	\$500,000–\$5,000,000+ per event	Included in retainer
Downtime per incident	Days to weeks	Hours to days
Regulatory penalty risk	High (NERC CIP: up to \$1M/violation/day)	Low (demonstrable due diligence)
Insurance premiums	Rising rapidly; coverage may be denied	Lower premiums; easier to obtain
Board/stakeholder confidence	Erodes after first incident	Sustained

SCADAIntel

SCADAIntel

1. ****Printability matters.**** Plant managers and OT directors print these for safety meetings and budget presentations. Avoid large solid color areas on interior pages (waste ink). Reserve full-bleed backgrounds for cover and back cover only. 2. ****Tables are the star.**** These guides live or die on their reference tables. Make tables scannable, well-spaced, and easy to read at 100% zoom on screen AN

Find consultants at scadaintel.com